DOSSIER TECHNIQUE DU TRAVAIL RÉALISÉ · ÉDITION PUBLIQUE

Éclair CMS, de la 1.14 à la 2.3

Refonte de l’architecture, migration depuis WordPress, passage à l’échelle et sécurité d’un CMS PHP léger, sans base de données. Du 4 au 13 novembre 2026.

8 versions
publiées en 7 jours, de la 1.14.0 (4 novembre) à la 2.3.0 (10 novembre)

1 158 → 1 490
vérifications automatiques, sur les sources comme sur l’archive construite (PR n° 28 comprise)

3 000 → 10 000
contenus par site, avec une page hors cache générée en 20 à 28 ms au maximum de la charge

730 → 889 Ko
poids de l’archive, sans dépendance ni base de données, malgré 7 fonctions et l’import WordPress

Auteur et mainteneur : Thierry Gustin
Méthode : développement assisté par Claude (Anthropic) avec Claude Code, sous la direction et la validation de l’auteur
Dépôt : github.com/Jacckisback/eclair-cms · licence AGPL-3.0
Établi le : 13 novembre 2026, d’après le dépôt (CHANGELOG, historique Git, tests)

1 Résumé

En neuf jours, Éclair est passé d'un CMS monolithique à une architecture modulaire où **le thème appartient au site**, où chaque compétence spécialisée est une **fonction optionnelle**, et où **un site WordPress entier peut être repris sans perdre une adresse**. Chaque étape a été publiée sous forme de mise à jour signée en un clic.

Les cinq résultats

- **Architecture 2.0.** Le thème d'un site vit dans `site/themes/`, un dossier que les mises à jour ne touchent jamais ; les personnalisations faites à la main sur une 1.x sont retrouvées et conservées automatiquement. Sept fonctions deviennent optionnelles et ne sont plus chargées par les sites qui ne s'en servent pas.
- **Migration depuis WordPress** en quatre étapes (2.0 à 2.3) : adresses exactes et anciens liens `?p=123`, import d'un export WordPress, paquet complet du plugin Eclair Export, puis transfert en une seule opération quelle que soit la taille du site.
- **Passage à l'échelle** de 3 000 à 10 000 contenus par site, avec un index léger, une recherche, un plan du site et des imports qui tiennent en mémoire.
- **Qualité vérifiée** : plus de 1 400 vérifications automatiques sur cinq versions de PHP, essais sur de vrais serveurs Apache et Nginx, audit d'accessibilité dans un navigateur réel, passage testé depuis les vraies archives 1.14.1 et 1.14.2.
- **Sécurité** : premier audit sans défaut critique ni élevé, corrections livrées avec leurs tests, et les incidents traités en transparence.

Ce que cela change pour un utilisateur

Avant (1.14)	Après (2.3)
Modifier un gabarit à la main : la mise à jour suivante l'écrase.	Le thème du site est protégé ; une mise à jour ne peut pas l'écraser, et l'archive qui tenterait d'y écrire est refusée en entier.
Toutes les fonctions dans le noyau, chargées ou non.	Sept fonctions à ajouter au besoin ; un site ne charge que ce qu'il utilise.
Migrer depuis WordPress : travail manuel, adresses à reprendre une par une.	Export, simulation, import ; adresses, redirections, SEO et images repris ; transfert direct par clé de liaison.
Jusqu'à 3 000 contenus par site.	Jusqu'à 10 000, avec des pages hors cache environ trois fois plus rapides à cette taille.
Mises à jour signées, sans contrôle automatique sur plusieurs versions de PHP (la 1.14.1 était cassée sous PHP 8.1).	Mêmes garanties de signature, avec des tests de PHP 8.1 à 8.5, sur serveurs réels, et un retour arrière automatique.

2 Chronologie

Huit versions publiées, chacune annoncée par une mise à jour signée (Ed25519), puis deux chantiers menés après la 2.3.0.

Version	Date	Ce qu'elle apporte
1.14.0	4 novembre	Google Discover (contrôles, tendances du jour), publicité AdSense conforme sur les articles, tableau de bord adapté à l'usage du site (média, affiliation, relance d'un ancien site).
1.14.1	5 novembre	L'installation détecte le fichier `.htaccess` oublié (caché sur Mac, souvent non envoyé par FTP) et explique comment l'envoyer.
1.14.2	7 novembre	Correctif : sous PHP 8.1, la 1.14.1 affichait ses pages en erreur 500 hors cache et ne pouvait plus se mettre à jour. Trouvé par la CI, corrigé et publié.
2.0.0	8 novembre	Refonte : thème protégé, fonctions optionnelles (7 livrées), migrations, contrats et validateur, adresses exactes et import WordPress, sauvegarde et restauration en ligne.
2.0.1	8 novembre	Correctif signalé par un utilisateur (expression régulière invalide), corrigé le jour même avec un test qui contrôle toutes les expressions du code.
2.1.0	9 novembre	Import du paquet du plugin WordPress *Eclair Export* : contenus, images, SEO, menus, catalogue WooCommerce, redirections, simulation et rapport de migration.
2.2.0	9 novembre	Revue complète du code, index léger, 10 000 contenus par site, imports WordPress à grande échelle, titres SEO et réponses 304 corrigés.
2.3.0	10 novembre	Migration WordPress en un seul transfert, par clé de liaison, sans téléchargement ni limite d'envoi.

Après la 2.3.0

Date	Chantier	État
13 novembre	Thierry Skill intégré à Éclair	**fusionné** PR n° 27 : le skill de direction artistique rejoint le dépôt et livre des thèmes Éclair conformes.
13 novembre	Audit de sécurité light et correctifs	**inclus** PR n° 28, qui contient ce document : quatre corrections, test qui échoue sur l'ancien code.

3 L’architecture 2.0

L’idée directrice : **le noyau reste petit et remplaçable, tout ce qui appartient au site est protégé, et chaque compétence est un module** avec son manifeste, ses droits et son cycle de vie.

Noyau d’Éclair (app/, assets/, index.php)
Contenus, éditeur, SEO, sécurité, mise à jour signée. Remplacé par chaque mise à jour, avec retour arrière automatique.

Fonctions optionnelles (livrées dans app/bundled/, ou importées dans site/extensions/)
Jamais chargées tant que le site ne les a pas ajoutées. Chacune porte ses routes, ses droits, ses réglages, ses traductions et ses migrations.

Ancien site | Sauvegardes Google Drive | Robots IA | Google Discover | Affiliation | Planning éditorial | Import WordPress

Le site (site/, data/, media/)
Thème du site, fonctions importées, contenus, réglages, images. **Jamais écrasé par une mise à jour** : le code refuse toute archive du noyau qui y écrit, et les tests comparent l’empreinte complète du dossier avant et après.

Trois couches, trois propriétaires : le noyau (les mises à jour), les fonctions (le site qui les ajoute), les données (le site).

Ce qui garantit la transition depuis la 1.x

- **Migrations identifiées et idempotentes** : les gabarits, le CSS et les actifs modifiés à la main sont retrouvés dans la copie de l’ancien code, rangés dans un thème « legacy » activé automatiquement ; l’apparence ne change pas.
- **Les sites qui utilisaient une fonction la gardent**, avec leurs données et l’adresse historique de leurs tâches planifiées.
- **Testé avec les vraies archives** 1.14.1 et 1.14.2 et leur propre outil de mise à jour, puis retour arrière vers l’ancienne version.
- **Rendu public identique à l’octet près** sur quatre sites de départ, vérifié par un test de référence à chaque modification.

Garde-fous retenus

- La mention légale de l’affiliation (LCEN, LSSI, Partenariat Amazon, `rel="sponsored"`) reste dans le noyau : retirer la fonction ne la supprime jamais d’une page publiée.
- Importer un thème ou une fonction (du code exécuté avec les droits du site) exige le droit Sécurité et le mot de passe, et rien ne s’active tout seul.
- Le registre des fonctions n’est même pas chargé par les pages publiques quand aucune fonction n’y déclare de route : problème trouvé par le budget mémoire, corrigé avant publication.

Contrats ouverts aux skills d’IA

Un contrat de thème, un contrat de fonction, leurs schémas, un validateur (`tools/validate.php`), des exemples et un guide permettent à un skill (par exemple ceux de Claude) de produire un thème ou une fonction. Éclair vérifie tout avant installation et ne l’active qu’avec l’accord d’une personne. Les bases sont posées ; une boutique de skills n’existe pas encore.

4 Migration depuis WordPress

Objectif : un site WordPress peut devenir un site Éclair **sans perdre une adresse ni son référencement**. Quatre versions successives ont construit le parcours.

Version	Étape	Détail
2.0.0	Reprendre les adresses	Adresses exactes (`/2024/03/article/` avec le « / » final, `.html` , accents) servies avant toute réécriture ; anciens liens `?p=123` , `?page_id=` , `?attachment_id=` redirigés en une seule 301 ; paramètres marketing sans variante de cache ; import d'un export WordPress (articles, pages, catégories, images).
2.1.0	Paquet Eclair Export	Contenus, images, documents PDF, SEO (Yoast, Rank Math, AIOSEO), menus, catalogue WooCommerce, redirections ; vérification du paquet avant toute écriture, simulation, import repris là où il s'arrête, rapport de migration pour le client.
2.2.0	Grands sites	Fichiers d'export lus au fil de l'eau (jusqu'à 10 000 contenus et 512 Mo), import en ligne de commande sans limite de temps, import plus fidèle (paragraphes de l'éditeur classique, légendes, vidéos, galeries, listes imbriquées, SEO repris).
2.3.0	Un seul transfert	Une clé de liaison valable deux heures permet à WordPress d'envoyer son paquet directement au site, par morceaux et avec reprise : ni téléchargement, ni limite d'envoi, ni FTP. Search Console, logo, profils sociaux et dates de modification d'origine sont conservés.

Résultats mesurés et documentés dans le CHANGELOG

Mesure	Résultat
Site WordPress réel de 500 articles (Elementor, Divi, WooCommerce, deux langues) : anciennes adresses vérifiées	635 contrôlées, 0 erreur 404
Import d'un export de 3 500 articles en ligne de commande	227 s → 72 s
Import d'un paquet Eclair Export de 3 500 articles	394 s → 210 s
Export de 9 990 articles importé	10 min 40 s
Paquet de 9 990 articles (44 Mo de données) importé avec PHP limité à 128 Mo	pic à 80 Mo, 9 990 liens internes réécrits, 0 erreur

> **Sécurité de la réception (2.3.0).** L'adresse de réception n'existe que pendant qu'une clé est active ; seule l'empreinte de la clé est conservée ; dix clés fausses en dix minutes bloquent l'adresse du demandeur ; chaque archive est vérifiée par son empreinte SHA-256 avant d'être acceptée ; la clé ne donne qu'un droit, déposer des archives ZIP nommées `eclair-export-*.zip` . L'import lui-même reste lancé par une personne connectée. Lors de l'audit, l'archive n'est jamais décompressée sur le disque et aucune faille n'a été trouvée sur ce point.

5 Passage à l'échelle et performances

La 2.2.0 est issue d'une revue complète du code (vitesse, SEO et GEO, migration, robustesse), puis du travail nécessaire pour héberger de grands sites. **Ce que montre une page ne change pas** : le rendu public reste identique à la référence, vérifié par le même test passé une seconde fois à travers l'index léger.

Un index léger pour les pages publiques

À partir d'environ 450 contenus, les pages publiques lisent un index léger (une ligne courte par contenu) au lieu de tout l'index, puis relisent seulement les quelques contenus qu'elles affichent. Il est dérivé de l'index, reconstruit seul quand il manque ou est périmé, et les petits sites gardent exactement le fonctionnement d'avant.

Mesure (page non servie par le cache)	Avant	Après
Page générée à 10 000 contenus	70 ms, 46 Mo	**20 à 28 ms, 10 Mo**
Page générée à 3 000 contenus : mémoire	15 Mo	**5,5 Mo**
Page générée à 3 000 contenus : durée	environ 20 ms	**7 à 15 ms**
Plan du site à 10 000 contenus	56 Mo	**15 Mo (290 ms)**
`llms.txt` à 10 000 contenus	56 Mo	**17 Mo (240 ms)**
Recherche publique à 10 000 contenus	110 ms, 57 Mo	**90 ms, 39 Mo**
Page servie par le cache	inchangée : un seul fichier PHP, 0,1 ms	

Sources : CHANGELOG 2.2.0 et description de la pull request n° 24 (outil `php tools/measure.php --pages=N`). Mesures rapportées lors de ces travaux ; elles n'ont pas été refaites pour ce document.

Autres améliorations de la 2.2.0

- **Titres SEO abîmés** : un titre commençant par «, “, … ou € perdait le premier octet du caractère et la balise `<title>` commençait par un caractère illisible. Corrigé.
- **Réponses 304 jamais envoyées** derrière Nginx, Apache, LiteSpeed ou Cloudflare, qui transforment le validateur : un visiteur fidèle retéléchargeait chaque page en entier. Éclair reconnaît maintenant ces formes.
- **La recherche ne bloque plus la publication** quand l'index de recherche est plein : le contenu est toujours enregistré.
- **Une limite documentée** : à 10 000 contenus, l'administration et chaque enregistrement lisent encore tout l'index ; c'est ce qui fixe le plafond.

Le budget comme garde-fou

Chaque commit vérifie des plafonds de poids de l'archive, de mémoire et de nombre de fichiers chargés. Ils ont détecté au moins deux vraies régressions avant publication, dont le registre des fonctions chargé par les pages publiques (2,11 Mo → 2,53 Mo de mémoire sur l'accueil). Les relèvements de plafond sont toujours expliqués dans le CHANGELOG.

6 Qualité et vérifications

Contrôle	Ce qui est vérifié	Résultat
Suite automatique	Tests unitaires et HTTP sur les sources, puis sur l'archive réellement construite, sans clé de signature.	1 158 → 1 490 vérifications
Cinq versions de PHP	Intégration continue de PHP 8.1 à 8.5.	verte
Vrais serveurs	Apache 2.4 avec `.htaccess` livré, Apache avec l'ancien `.htaccess` d'une 1.x, Nginx avec PHP-FPM et les règles de la documentation : installation, cache, en-têtes, adresses exactes, 23 contrôles sur des fichiers sensibles ou piégés, jamais servis ni exécutés.	37 sur 37, dans les trois cas
Passage depuis les vraies versions	Mise à jour par l'outil d'origine de la 1.14.1 puis de la 1.14.2, personnalisations conservées, retour arrière vers l'ancienne version.	réussi
Accessibilité	axe-core (WCAG 2.1 A et AA) dans Chromium sur 13 écrans d'administration, défilement horizontal à 390 px, erreurs JavaScript.	0 violation après 2 corrections
Rendu public	Quatre sites de départ comparés à une référence, deux fois (index complet, puis index léger).	identique à l'octet près
Mises à jour signées	Signatures Ed25519 vérifiées avec la clé publique des sites, empreinte et taille, numéro de série croissant ; canal public relu octet par octet après chaque publication.	à chaque version

Incidents traités en transparence

Incident	Cause et réponse	Délai
1.14.1 cassée sous PHP 8.1	Un type de retour réservé à PHP 8.2 et une constante cURL de PHP 8.2 empêchaient l'affichage des pages hors cache et la mise à jour en un clic. Détecté par la CI avec la vraie archive ; corrigé dans la 1.14.2 ; un test interdit désormais ces constructions.	2 jours après la 1.14.1
Expression régulière invalide (2.0.0)	Signalée par un utilisateur : pages normales, mais un avertissement journalisé à chaque page hors cache. Corrigée dans la 2.0.1 ; un test vérifie désormais que les 305 expressions du code compilent.	le jour même
Brouillons vides (audit)	Un enregistrement avec un corps invalide créait un brouillon vide. Corrigé dans la PR n° 28 ; le test échoue sur l'ancien code.	le jour de l'audit

7 Sécurité

Un premier audit « light » a porté sur le code des zones à risque, puis sur des requêtes hostiles contre une installation fraîche de la version 2.3.0. **Aucun défaut critique ni élevé.** Un audit approfondi est prévu ensuite.

Ce qui a été attaqué, et a tenu

- **Envois de fichiers** : PHP déguisé en image, SVG piégé, `.htaccess`, `../` refusés ; des images valides cachant du PHP dans leurs métadonnées sont acceptées mais ressortent sans ce code après ré-encodage.
- **Accès sans connexion** : l'administration et l'API répondent 302 ou 401.
- **CSRF** : refusé sans jeton, et même avec un bon jeton si l'origine est étrangère.
- **Connexion** : blocage anti-force-brute ; aucune énumération de comptes (environ 21 ms que le compte existe ou non).
- **Redirections ouvertes** : neuf tentatives, aucune ne quitte le site.
- **En-tête `Host` falsifié** : jamais reflété dans les pages.
- **XSS** : recherche et page 404 sans reflet ; cinq sorties HTML brutes seulement dans toute l'interface, d'origine sûre.
- **Courrier** : injection d'en-têtes bloquée à deux niveaux ; formulaire de contact sans captcha qui n'envoie rien sans le jeton JavaScript.

S'y ajoutent les contrôles de chemins des restaurations et des imports (liste blanche, `..` et liens symboliques refusés), l'absence de secret dans le code et l'historique, et des requêtes sortantes qui visent toutes des services fixes.

Constats et traitement

#	Gravité	Constat	Traitement
1	faible	Un enregistrement avec un JSON invalide créait un brouillon vide.	corrigé PR n° 28
2	faible	HSTS désactivé par défaut, même en HTTPS.	corrigé nouvelles installations seulement
3	faible	Pas de politique de signalement des vulnérabilités.	corrigé `SECURITY.md`
4	info	Deux actions de la CI figées par numéro de version et non par commit.	corrigé + Dependabot
5	info	PHP 8.1, en fin de support, reste accepté.	conservé, PHP 8.2+ recommandé

> **Portée.** Ce premier passage est volontairement léger : ni fuzzing, ni revue ligne à ligne. Pour signaler une vulnérabilité, voir `SECURITY.md` à la racine du dépôt.

8 Thierry Skill, méthode et rôles

Thierry Skill intégré à Éclair

Le skill de direction artistique pour Claude Code (ancien dépôt `thierry-skills`) fait désormais partie du dépôt d'Éclair, dans `skills/thierry-skill/`. Il trouve l'idée propre à l'activité d'un client, en déduit un système complet (typographie, couleur, composition, mouvement), regarde le rendu à trois largeurs et le note avant de conclure. Son nouveau mode **« Livrer sur Éclair »** essaie d'abord les réglages d'Éclair, puis produit un thème du site conforme au contrat, validé par `tools/validate.php` et prêt à importer. Un thème de départ est livré, et un test vérifie à chaque modification qu'il s'installe, s'active et s'affiche, y compris la gestion du mode sombre. Installation : `npx skills@latest add Jacckisback/eclair-cms`.

Qui a fait quoi

Rôle	Responsabilités
Thierry Gustin auteur et mainteneur	Vision du produit et priorités ; décision de chaque fusion et de chaque publication ; consignes de sécurité (aucune publication sans demande explicite) ; relation avec les utilisateurs, dont le signalement qui a mené à la 2.0.1.
Claude (Anthropic) via Claude Code	Implémentation, tests, vérifications sur serveurs et navigateur, audit, rédaction de la documentation et des notes de version, dans le cadre fixé par l'auteur. Les commits portent la mention `Co-Authored-By`.

Du 4 au 13 novembre 2026, l'historique compte 60 commits : 44 signés « Claude » et 16 signés Thierry Gustin, ces derniers étant surtout les fusions de pull requests. Entre la 1.14.0 et la branche principale : 272 fichiers modifiés, 18 685 lignes ajoutées et 907 supprimées. Le code du noyau compte environ 31 600 lignes de PHP et les tests environ 12 700 lignes.

Principes de travail

- **Mesurer avant d'affirmer** : chaque promesse du CHANGELOG renvoie à un test ou à une mesure.
- **Ne jamais publier sans demande explicite** : fusion, annonce et signature sont des décisions séparées.
- **Un test qui échoue sur l'ancien code** accompagne chaque correctif de sécurité.
- **Dire ce qui n'est pas fait** : le reste à faire figure dans `docs/STATUS-2.md`.

9 Reste à faire et références

Prochaines étapes, par ordre d'importance

#	Action	Qui
1	Activer le signalement privé de vulnérabilités dans les réglages GitHub, auquel `SECURITY.md` renvoie.	Thierry Gustin
2	Audit de sécurité approfondi, avec un outil dédié.	Thierry Gustin
3	Mettre à jour un de ses propres sites en 2.x et le vérifier avant chaque annonce de version.	Thierry Gustin
4	Archiver l'ancien dépôt `thierry-skills` avec un renvoi vers `skills/thierry-skill` ; vérifier les pages « Release » GitHub des versions publiées (l'environnement ne peut pas envoyer les tags).	Thierry Gustin
5	Vérifier sur un vrai serveur LiteSpeed (même `.htaccess` qu'Apache, non testé) ; extractions reportées : AdSense, boutique, IA et MCP.	développement

Références

Pour	Où
Détail de chaque version	`CHANGELOG.md`
Guide de passage à la 2.0	`docs/UPGRADE-2.md`
Architecture et état de la refonte	`docs/ARCHITECTURE-2.md` , `docs/STATUS-2.md`
Contrats pour thèmes et fonctions, guide des skills	`docs/THEME-CONTRACT.md` , `docs/EXTENSION-CONTRACT.md` , `docs/SKILLS-GUIDE.md`
Mesures et budgets	`docs/MEASURES.md` , `tools/budgets.json`
Vérification sur serveurs réels, accessibilité	`tools/ci-servers.sh` , `tests/servers.php` , `tools/a11y-audit.js`
Pull requests principales	n° 17 (2.0), 18 (1.14.2), 20 (2.0.1), 24 (2.2.0), 27 (Thierry Skill), 28 (audit)
Politique de sécurité	`SECURITY.md` (PR n° 28)

> **Limites de ce document.** Les chiffres proviennent du dépôt au 13 novembre 2026. Les mesures de performance et de migration sont celles consignées dans le CHANGELOG et les pull requests lors des travaux, et n'ont pas été refaites pour ce document. Les versions 2.1.0 à 2.3.0 sont décrites d'après leur CHANGELOG. Le compte de 1 490 vérifications inclut la PR n° 28, qui contient ce document (1 484 sur la branche principale avant sa fusion).